

Security & compliance

AI Pre-Bill Audit — one-page summary for healthcare buyers. Full content: <https://ai-billing-audit.ashbi.ca/security>. For redlines, the BAA, or the HIC-Agent agreement, email legal@ai-billing-audit.ashbi.ca.

1. Your data stays in the region you choose

Canadian customer data lives in AWS ca-central-1 (Montreal). US customer data lives in AWS us-east-1 (N. Virginia). You pick the region at sign-up. We do not replicate across regions, and we do not move data out of the region you chose without written notice.

2. Encryption in transit and at rest

At rest: AES-256 on every volume, snapshot, and backup. Customer-managed keys are available on Enterprise.

In transit: TLS 1.3 only. Older protocol versions are disabled at the load balancer. Certificate rotation is automated.

Internal: service-to-service calls use mTLS inside the VPC. No plaintext hops.

3. We sign the contract before we see a single claim

For US customers we sign a Business Associate Agreement (BAA) under HIPAA. For Ontario and Alberta customers we sign a Health Information Custodian Agent (HIC-Agent) agreement under PHIPA. In both cases the agreement is countersigned **before** any customer data — including test claims — is uploaded or processed.

4. A human approves every recommendation

Our AI flags issues on draft claims. Your billing team reviews every flag in a split-screen view, side-by-side with the clinical note. The biller accepts, modifies, or dismisses each finding with one click. Nothing is submitted to the payer without a human sign-off. That human-in-the-loop is also your **Federal False Claims Act shield**. The AI is a decision-support tool, not the decision-maker. Liability for the claim stays with the provider.

5. Flat fee. No percentage of revenue. No upcoding incentive.

Our pricing is a flat monthly fee per provider. There is no percentage-of-revenue model, no per-claim bonus, no "success fee" tied to the dollars we help you recover. We are paid the same whether the AI flags five issues or five hundred.

This matters because the Anti-Kickback Statute (AKS) treats any compensation tied to federal healthcare program revenue as a potential violation. A flat fee is the standard safe harbor. We chose it on purpose, and we will not change it.

6. Tamper-evident audit log on every recommendation

Every AI flag, accept, modify, and dismiss is written to an append-only `audit_trail` table. Each row carries a **SHA-256 hash-chain cryptographic signature** computed over the previous signature plus the row contents (event id, timestamp, user, action, patient hash, data elements, model run id). The first row in a chain uses 64 ASCII zeros as the previous signature. A built-in `verify_chain()` walks the chain in timestamp order and returns the first row whose recomputed signature does not match the stored one. If it returns None, the chain is intact. If it returns a row id, that row (or one before it) has been altered. Implementation: `src/audit_log.py`, plus the unit test and the verification runbook in `docs/RUNBOOK.md`.

Compliance matrix

Same controls, mapped to each law and framework we commit to on day one.

Law or framework	What it requires	Control that satisfies it
PHIPA (Ontario)	Health information handled only by HIC-Agents under a written agreement, with appropriate safeguards.	HIC-Agent agreement signed before any data is accepted; AES-256 + TLS 1.3; ca-central-1 storage; hash-chain audit log.
HIA (Alberta)	Custodianship, affiliate agreements, and safeguards for individually identifying health information.	Affiliate agreement model mirrored from HIC-Agent; same encryption and residency controls as PHIPA.
HIPAA (US)	Administrative, physical, and technical safeguards for PHI; BAAs with business associates.	BAA signed before any data is accepted; AES-256 + TLS 1.3; us-east-1 storage; hash-chain audit log; HITL approval.

Law or framework	What it requires	Control that satisfies it
PIPEDA (federal Canada)	Consent, limiting use, accuracy, safeguards, openness, individual access.	ca-central-1 residency; encryption; audit log; patient identifiers hashed (salted SHA-256) before storage.
AIDA (Alberta)	Consent, anonymization, and access controls for AI-driven decisions affecting individuals.	HITL approval on every flag means a human, not the AI, makes the final call; explainability data attached.
US state privacy (CCPA/CPRA, WA My Health My Data)	Notice at collection, opt-out of sale/sharing, minimum necessary, special protections for consumer health data.	No sale or sharing of customer data; minimum-necessary access controls; us-east-1 residency; deletion on contract end.
Anti-Kickback Statute (AKS)	No remuneration tied to federal healthcare program business.	Flat monthly fee per provider. No percentage of revenue, no per-claim bonus, no recovery-linked compensation.

Contact: legal@ai-billing-audit.ashbi.ca (BAA / HIC-Agent), hello@ai-billing-audit.ashbi.ca (general)